

Cybersecurity for global Aviation

A Trust Framework enabling global secure aviation interoperability



FAA

Problem Statement

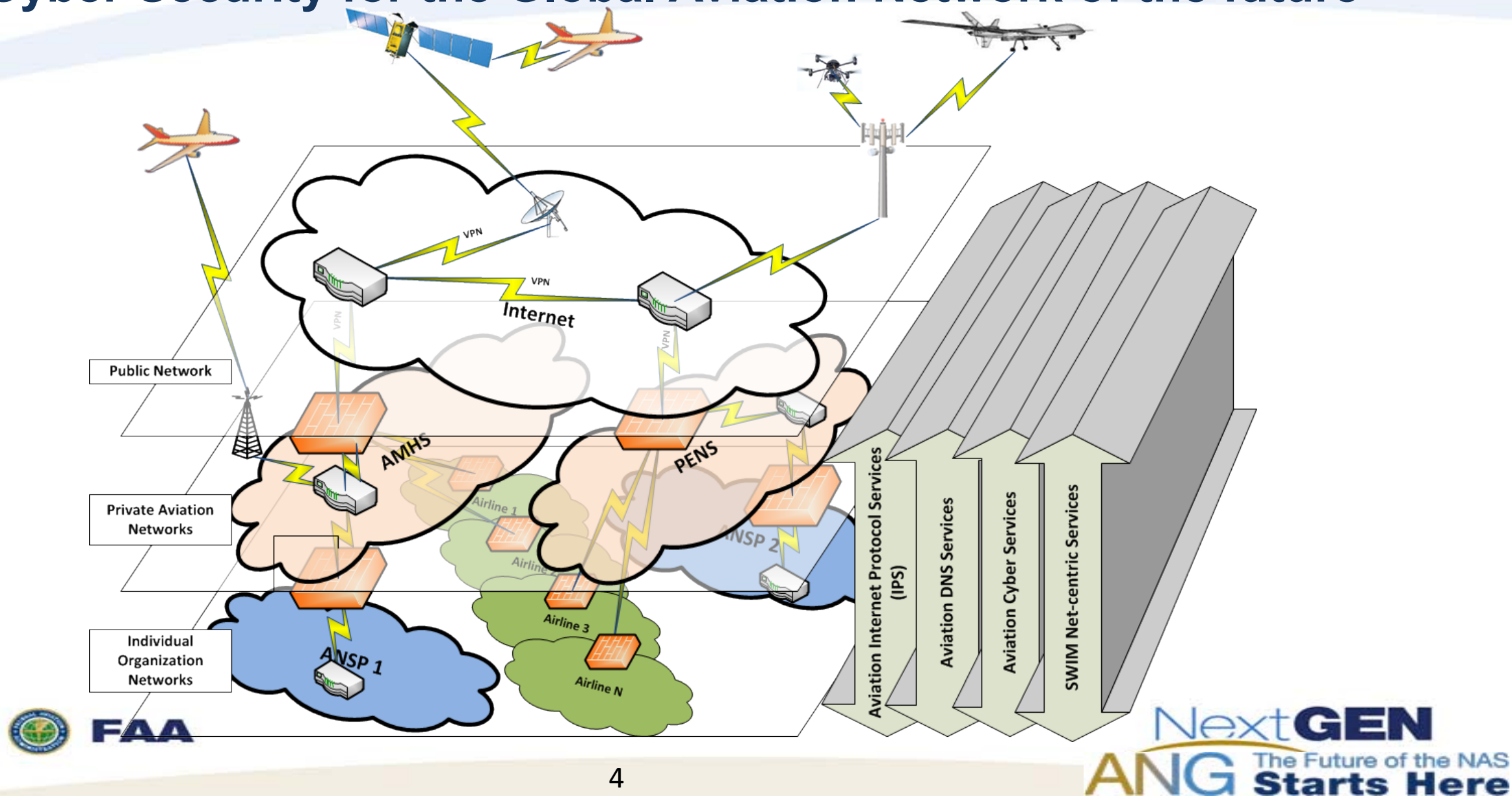
- Global economy is driving an increase in aviation capacity and efficiency
- Efficiency and capacity increases are enabled through Aviation Automation of Command and Control
- Automation of Command & Control requires increased digital information exchange
- Compromising digital information exchange for Command & Control has a significant economic and safety impact
- Efficient use of increased digital communications requires the use of open, standardized COTS solutions
- Use of open and standardized COTS software, hardware and communication protocols will lead to increased inter-connectivity and a larger security risk exposure
 - ✦ Use of internet based technologies increases the Cyber attack surface
 - ✦ Existing internet Cyber hacking community can apply their techniques to Civil Aviation

Vision

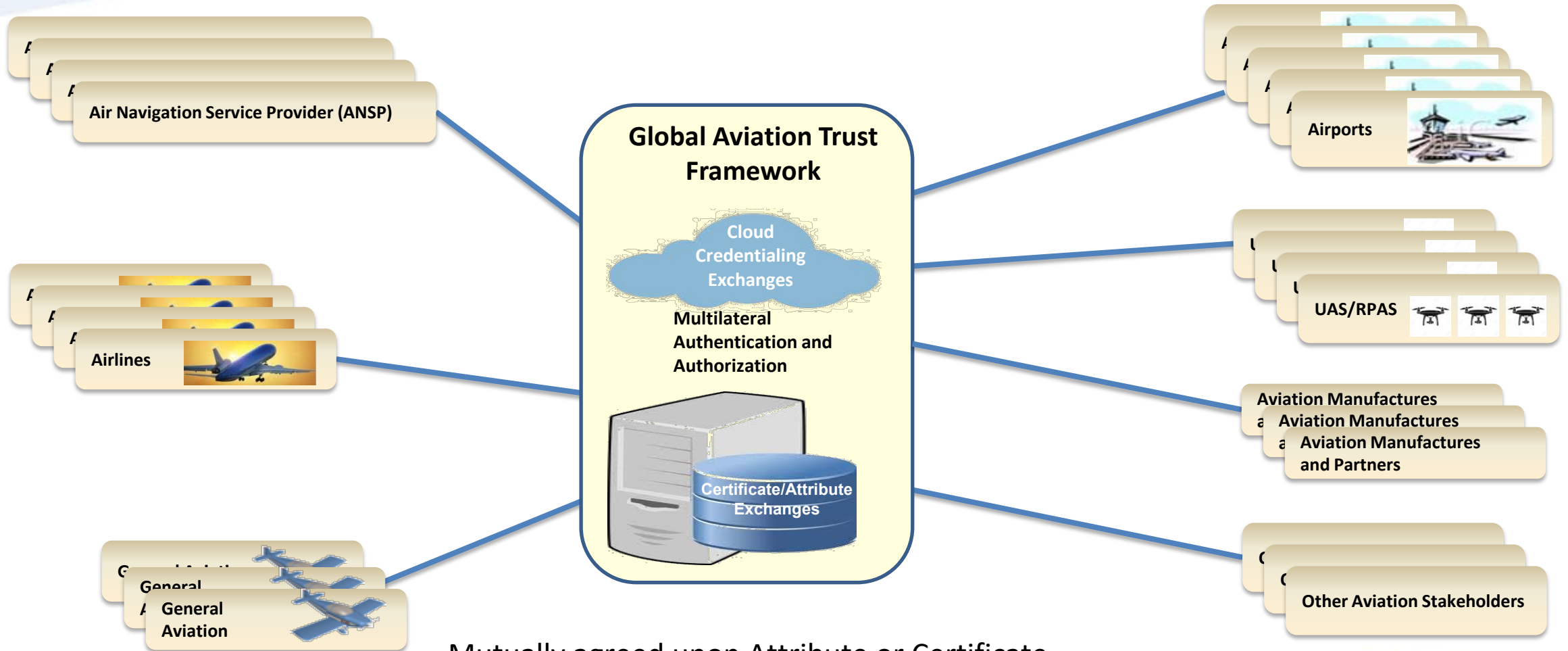
- Protecting the economy and safety of the aviation system against impacts from compromised digital information exchange, requires a Global, Unified approach to a Cyber Security solution
 - ✦ Current solutions are one off and point to point
- Establishing Global “Trust” in the user and system identities, exchanging digital data, is a fundamental requirement to enable a Cyber Security solution that is interoperable between all Aviation users
- ICAO is uniquely positioned to enable Cyber Security “Trust” between members and member systems world wide



Cyber Security for the Global Aviation Network of the future

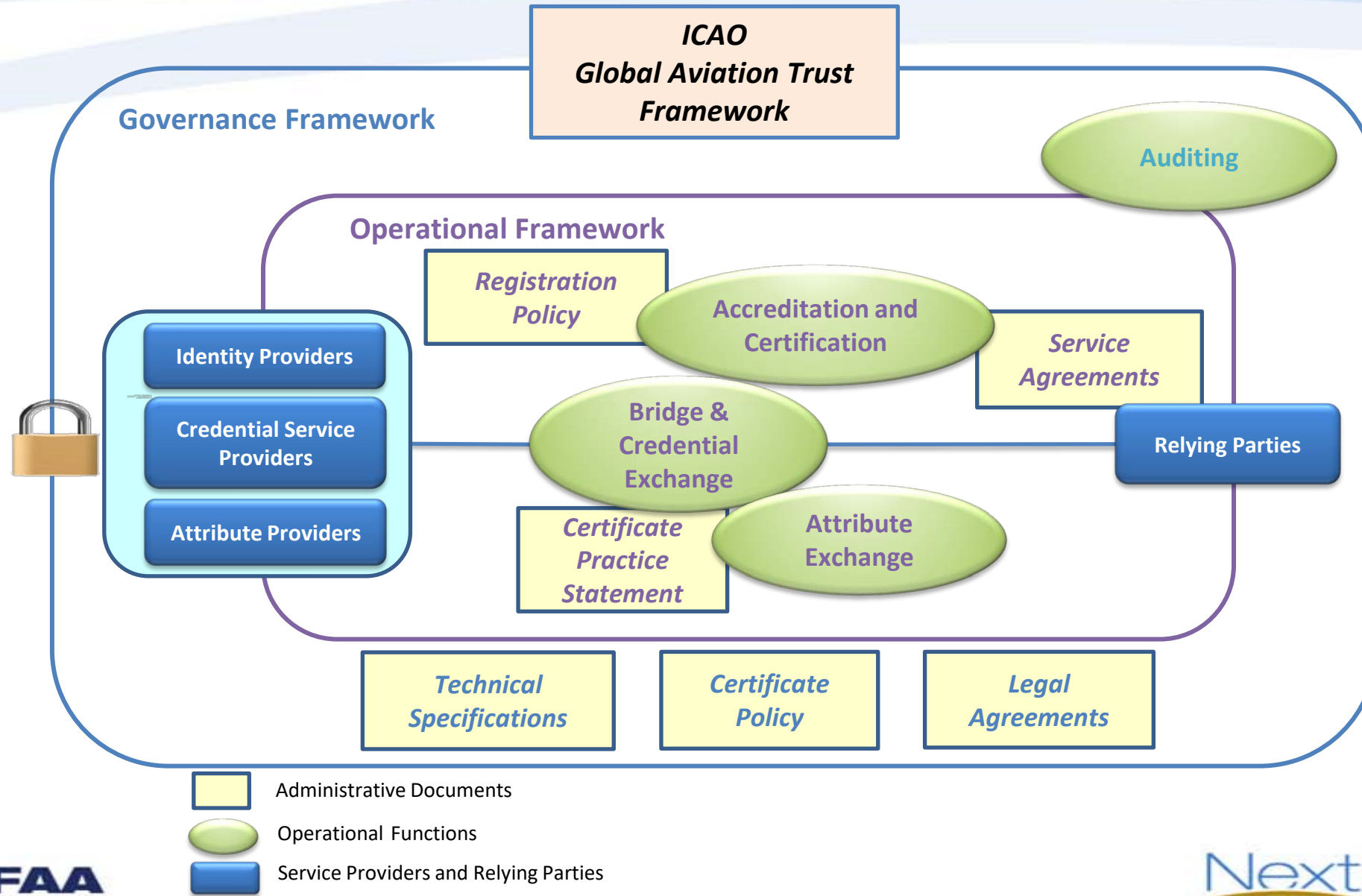


ICAO Trust Framework



Mutually agreed upon Attribute or Certificate based Credentialing to establish trust

Trust Framework for Cyber Identity & Access Services



Governance Trust Framework

- **Consists of a set of agreed documents managed and applied by a group of members governing the framework**
 - ✦ **Legal Agreements**
 - Liability and risk (legal, commercial and operational) addressed and agreed between the members
 - ✦ **Certificate Policy**
 - Document which states the different actors of Trust framework, their roles and their duties
 - ✦ **Technical Specifications**
 - The tools, techniques and processes used to link identity management systems and Public Key Infrastructures
 - ✦ **Auditing and Auditing Policy**
 - Monitoring, reviewing, and reporting on conformance with rules, policies, and requirements

Operational Trust Framework

- **Administrative Functions**

- **Registration Policy**

- The policy used to verify the identity of entities requesting their digital certificates to be stored at the Certificate Authority (CA)

- **Certificate Practice Statement**

- Practices that a particular CA employs in managing the certificates that it issues and should describe how the CA is interpreted and implemented by the CA

- **Service agreements**

- Set of contracts, regulations or commitments that enable participating actors to rely on certain assertions by other actors to fulfill their information security requirements

- **Operational Functions**

- **Accreditation and Certification**

- Process of evaluating, describing, testing, and authorizing systems for use

- **Bridge and Credential Exchange**

- Establishing a cross-certified, affiliated relationship to trust credentials at a level of assurance asserted by those credentials

- **Attribute Exchange**

- Real-time exchange of data specific to the transaction in hand, with the verified user present and with their full knowledge and permission

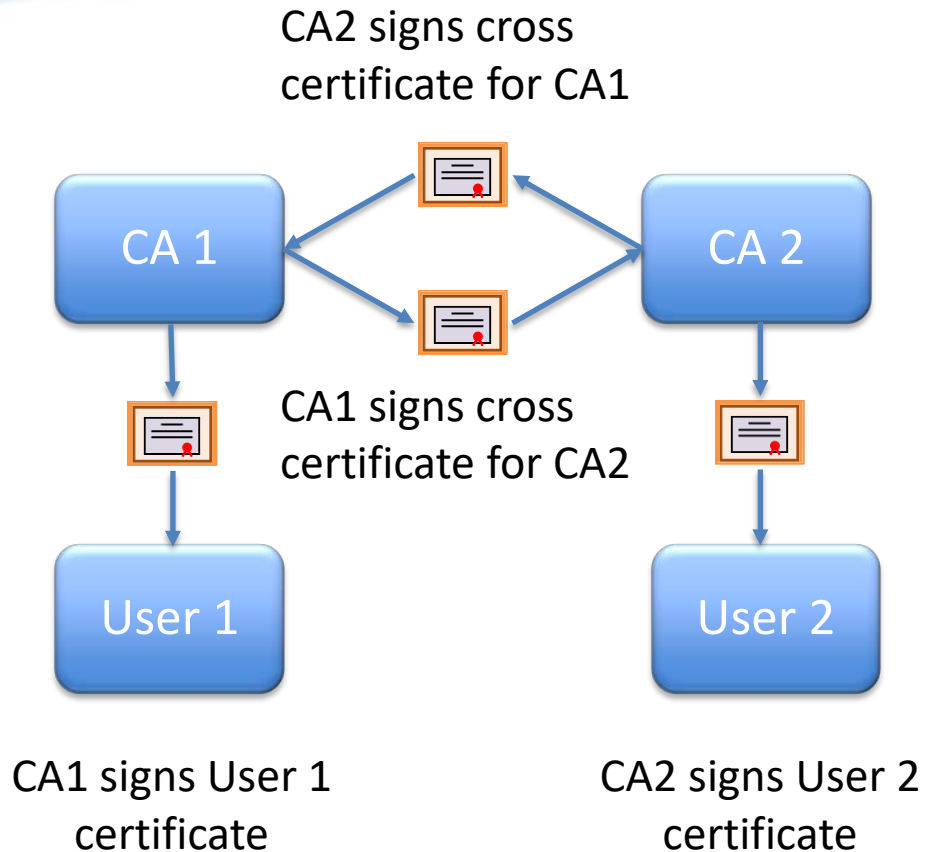


Level and types of Cyber Security

Trust Framework using X-509 Certificates supports the following:

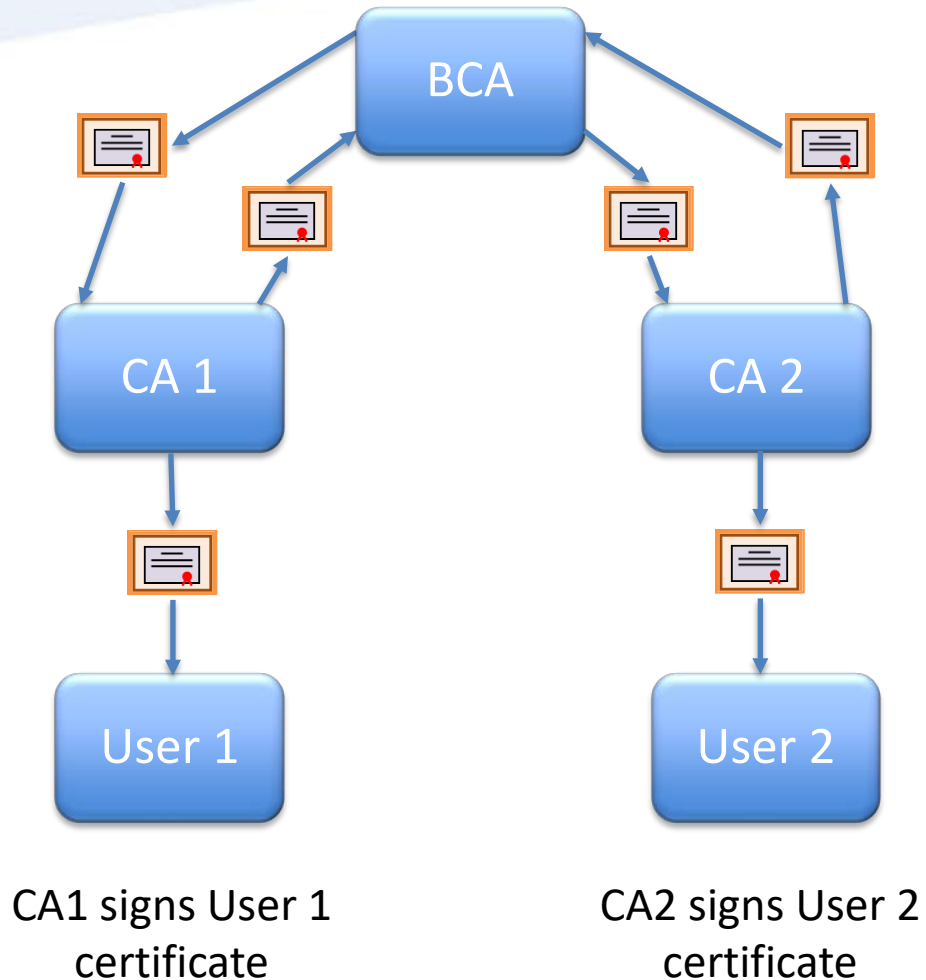
- Identification
 - ✦ A communication session is established via mutual authentication using trusted entities
 - ✦ Certificate attributes provide access rights
- Data Integrity
 - ✦ Sender's private key encrypts the Cyclic Redundancy Check or Hash Key
 - ✦ Decryption with sender's public key allows receiver to verify that payload is not modified
 - ✦ Low overhead on bandwidth and processing power since only header is encrypted
- Confidentiality
 - ✦ Sender encrypts payload with receiver's public key, receiver uses its private key to decrypt payload to ensure confidentiality
 - ✦ Highest overhead on bandwidth and processing power
- Nonrepudiation - The assurance of authenticity of the communication.

What is Trust “Cross” Certification



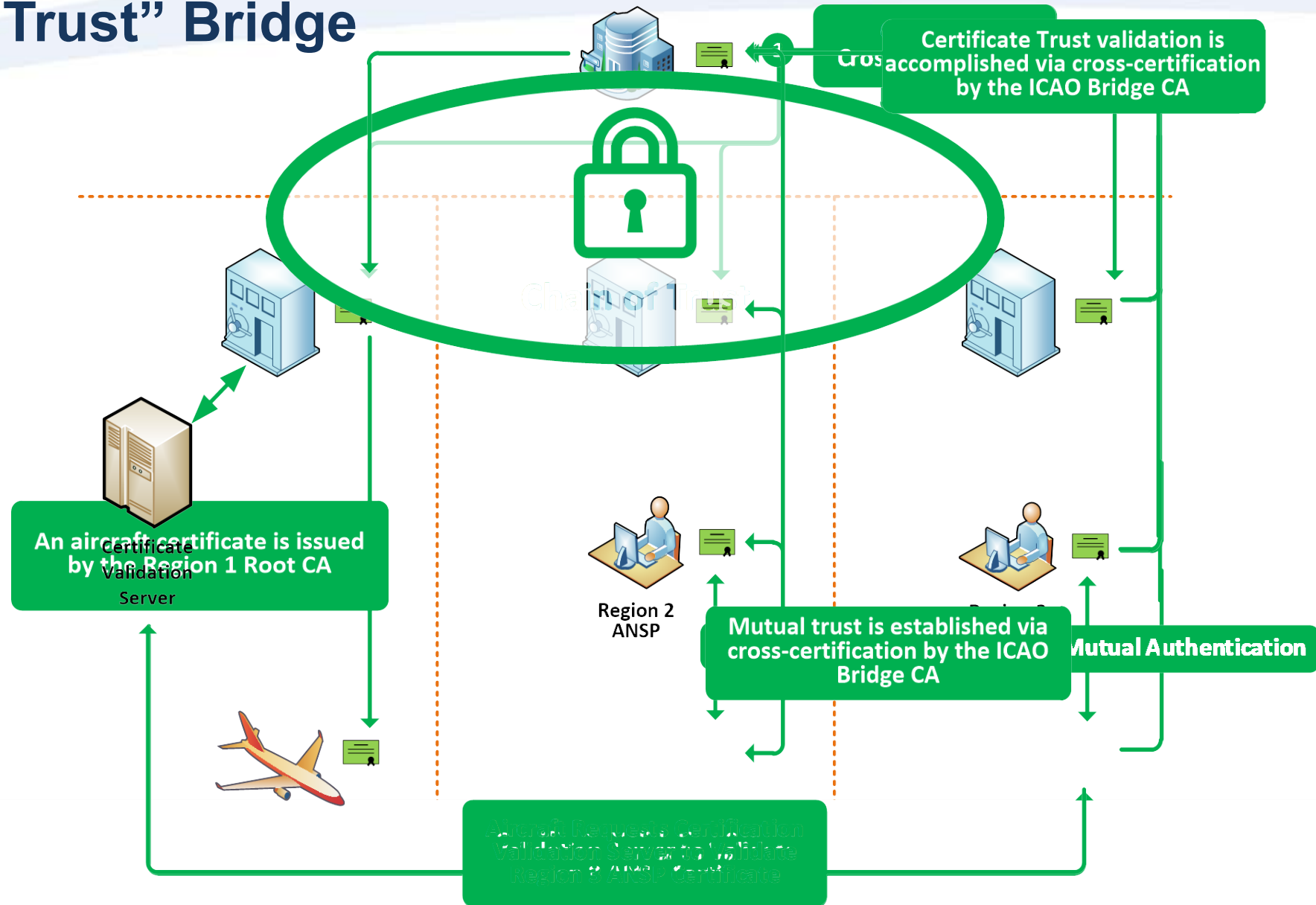
- User 1 uses a certificate that is signed by CA1 and “trusts” any user certificates issued and signed by CA1
- User 2 uses a certificate that is signed by CA2 and “trusts” any user certificates issued and signed by CA2
- In order for User 2 to trust User 1, CA2 can issue a “cross” certificate signing that it trusts CA 1 so that by association User 2 now can trust any users that have a signed certificate by CA 1
- In order for User 1 to trust User 2, CA1 can issue a “cross” certificate signing that it trusts CA 2 so that by association User 1 now can trust any users that have a signed certificate by CA 2

What is Trust “Bridge” Certification



- User 1 uses a certificate that is signed by CA1 and “trusts” any user certificates issued and signed by CA1
- User 2 uses a certificate that is signed by CA2 and “trusts” any user certificates issued and signed by CA2
- In order for User 2 to trust User 1, CA2 issues a “cross” certificate signing that it trusts BCA and BCA issues a “cross” certificate signing that it trusts CA1 so that by association User 2 now can trust any users that have a signed certificate by CA 1
- In order for User 1 to trust User 2, CA1 issues a “cross” certificate signing that it trusts BCA and BCA issues a “cross” certificate signing that it trusts CA2 so that by association User 1 now can trust any users that have a signed certificate by CA 2

Architecture approach: ICAO “Trust” Bridge



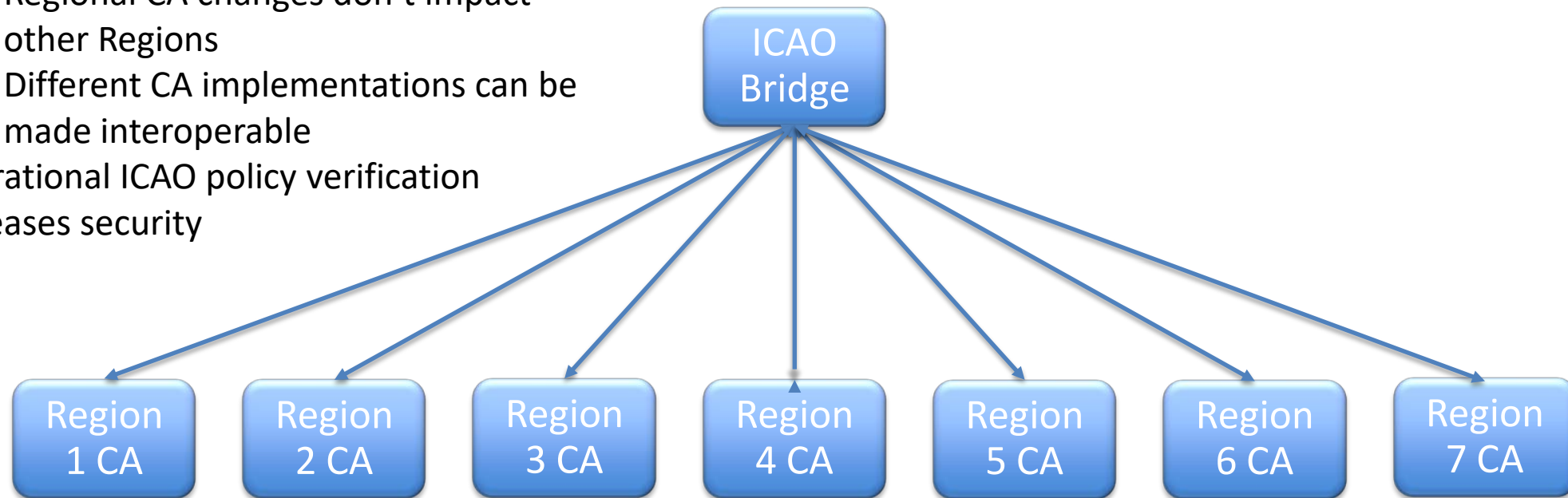
ICAO “Trust” Bridge

Advantages:

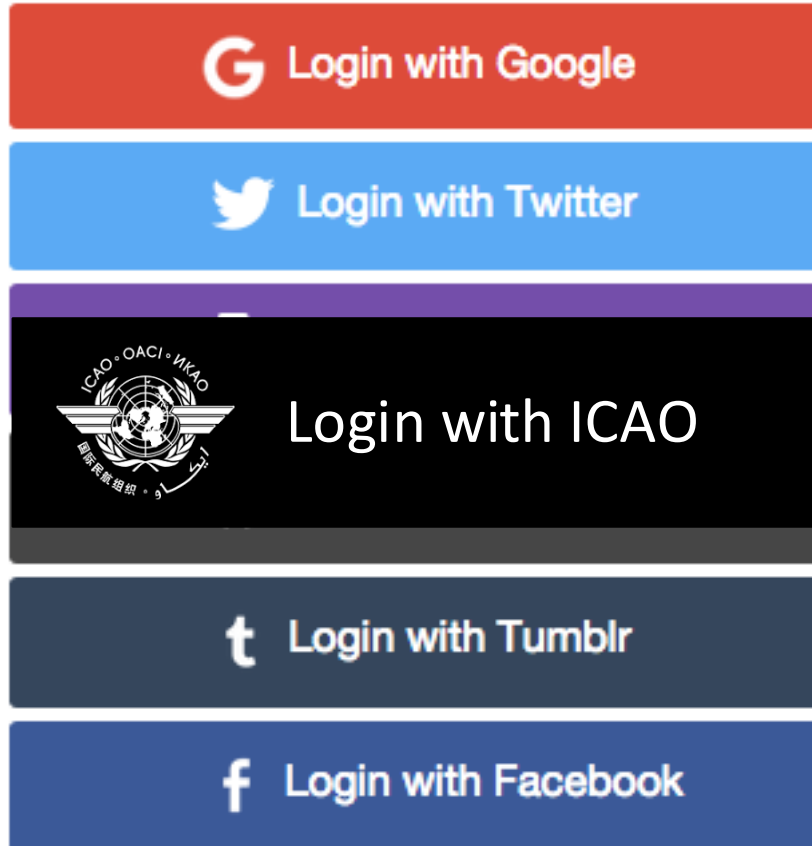
- Highly scalable
- Flexible
 - No impact on existing Regional CA configurations
 - Regional CA changes don’t impact other Regions
 - Different CA implementations can be made interoperable
- Operational ICAO policy verification increases security

Disadvantages:

- Any new member of the bridge is automatically trusted by all other parties, so adding members must be agreed
- ICAO Bridge needs to provide resiliency



No Region Left Behind

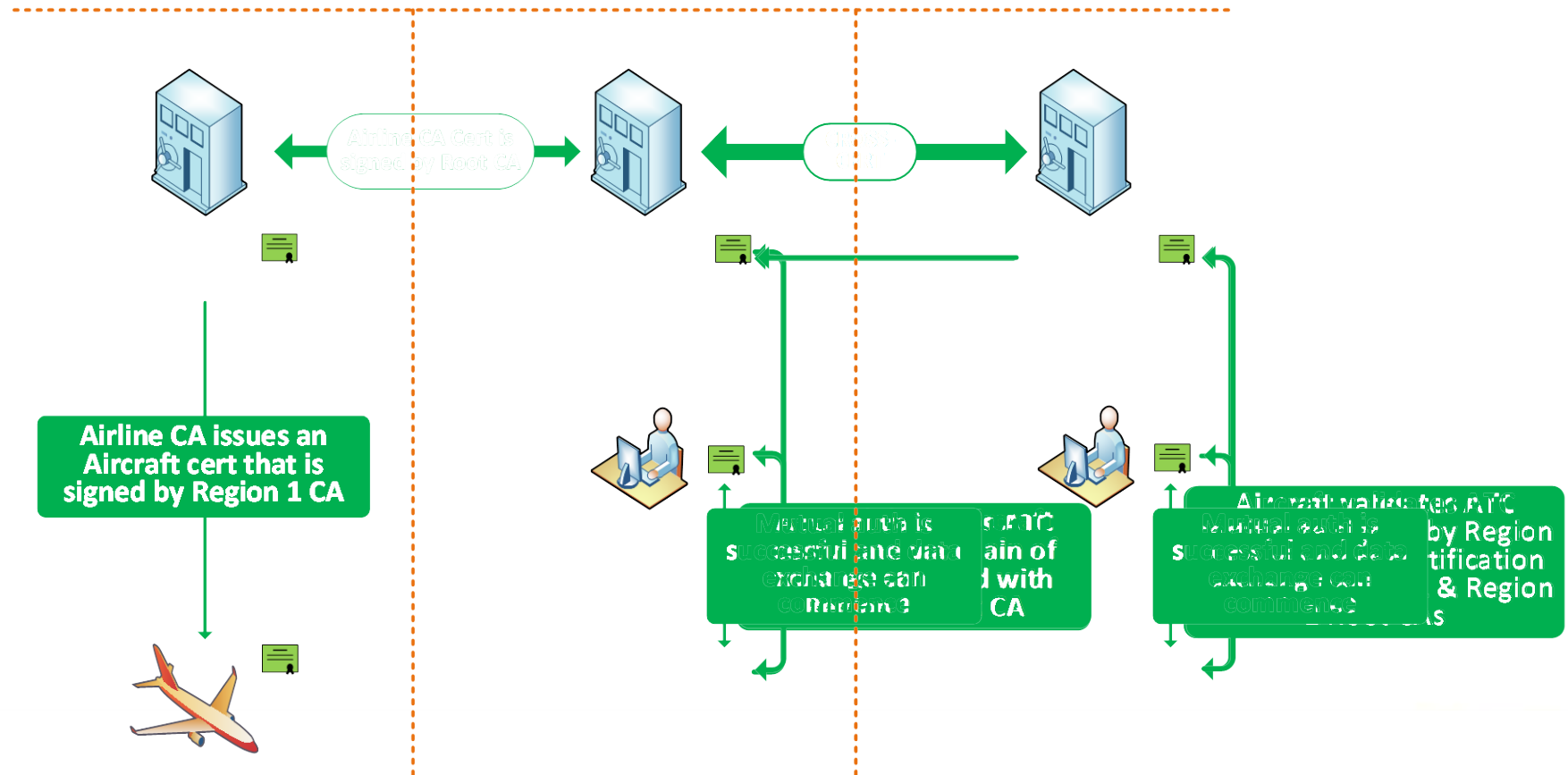


Login with Email

- Local Region/country provides security attributes based Registration Authority
- Web front-end hosted by service provider delegates identity verification to ICAO Bridge Authority
- ICAO Bridge Authority verifies authenticity and cross-certifies user and service provider

[Forgot your Password ?](#)

Architecture approach: Regional Cross-Certification



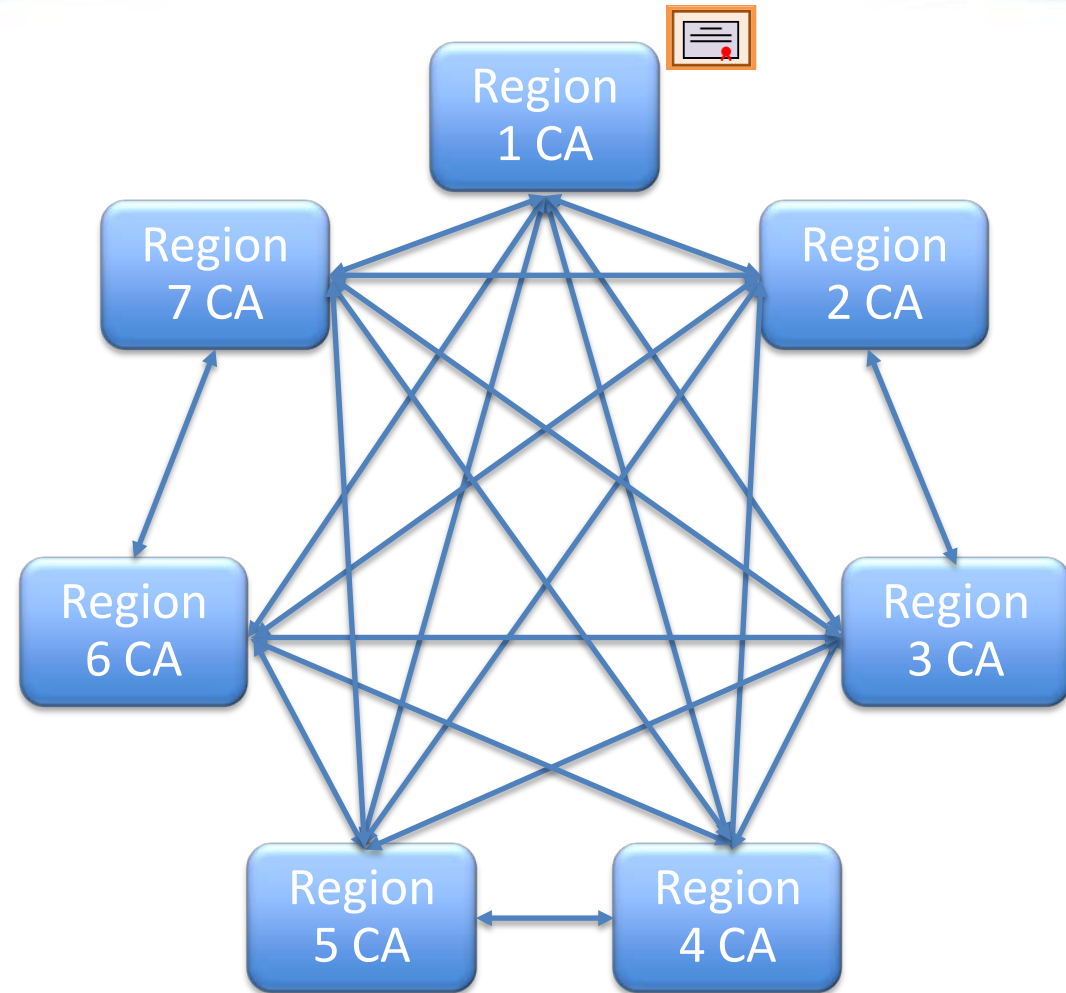
Regional Cross Certification

Advantages:

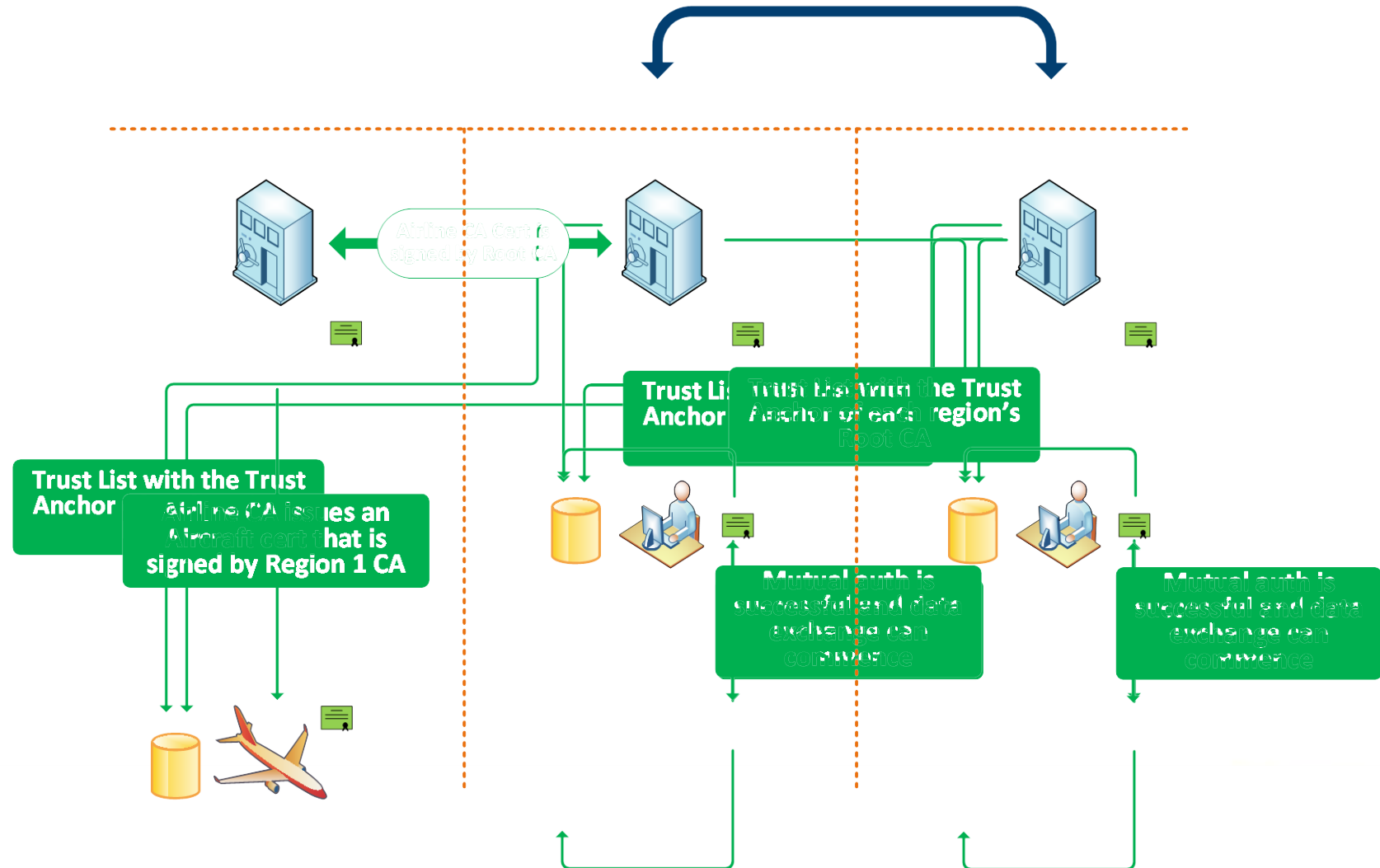
- Individual States and entities can choose who they want to cross-certify with and how
- No impact on existing Regional CA configurations
- Built-in resiliency for outages

Disadvantages:

- Does not work if some CAs choose not to trust each other
- Doesn't scale well
 - $N*(N-1)/2 = 21$ Bilateral trust agreements
- Can become a performance problem
 - 21 Paths for each Certificate Validation
 - Circular path validation could occur



Architecture approach: Individual Trust Lists



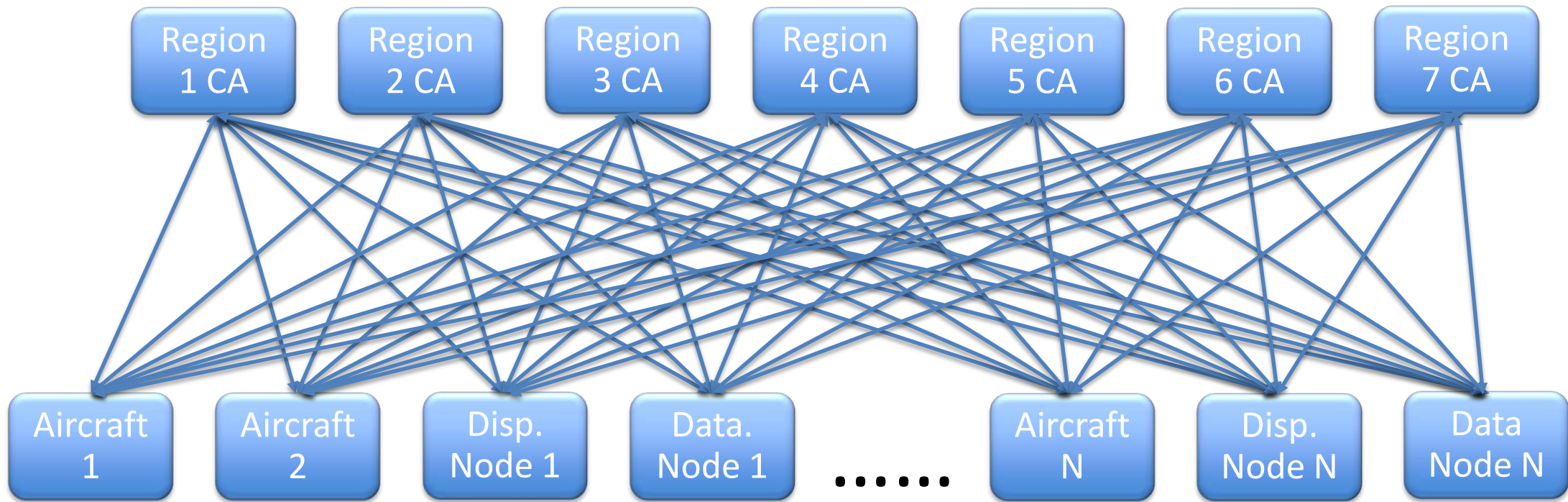
Trust List Certification

Advantages:

- Direct trust with minimal communication and performance overhead

Disadvantages:

- Does not scale at all
- Logistical and maintenance nightmare



Conclusion

- ICAO is uniquely positioned to enable Cyber Security “Trust” between members and member systems world wide
- The ICAO “Trust” Bridge architecture is the most flexible, scalable and secure solution without impacting existing region’s Cyber Solutions
- Certificate Validation Server will keep the Air to Ground communication overhead to a minimum
- No region is left behind